

THREAT ADVISORY



**VULNERABILITY
REPORT**

VMware Cloud Foundation has a significant RCE flaw

Date of Publication

October 27, 2022

Admiralty Code

A1

TA Number

TA2022235

Summary

A Remote Code Execution (RCE) vulnerability through the XStream open-source library tagged as CVE-2021-39144 in the VMware Cloud Foundation, which is a hybrid cloud platform for hosting enterprise workloads in private or public environments.

🔧 CVE Table

CVE	NAME	PATCH
CVE-2021-39144	remote code execution vulnerability via Xstream in VMware	✅
CVE-2022-31678	XML External Entity (XXE) vulnerability in VMware	✅

🔧 Potential MITRE ATT&CK TTPs

<u>TA0001</u> Initial Access	<u>TA0002</u> Execution	<u>TA0004</u> Privilege Escalation	<u>TA0008</u> Lateral Movement
<u>T1190</u> Exploit Public-Facing Application	<u>T1569</u> System Services	<u>T1068</u> Exploitation for Privilege Escalation	<u>T1055</u> Process Injection
<u>T1210</u> Exploitation of Remote Services			

Technical Details

#1

The severity of the RCE bug CVE-2021-39144 has been assessed since it can be remotely exploited by unauthenticated threat actors in minimal complexity attacks that do not require user interaction. The vulnerability exists as a result of incorrect input validation in xStream. A remote attacker can send specially crafted XML data to the program and execute arbitrary code on the target system.

#2

There were also updates released for a second bug (CVE-2022-31678), which might result in denials of service or the exposure of information after successful XML external entity injection (XXE) attacks.

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2021-39144	NSX Data Center for vSphere: 6.2.0 - 6.4.13 & Cloud Foundation: 3.11	cpe:2.3:a:vmware:nsx_data_center_f or_vsphere:-:*:*:*:*:*	CWE-94
CVE-2022-31678	NSX Data Center for vSphere: 6.2.0 - 6.4.13 & Cloud Foundation: 3.11	cpe:2.3:a:vmware:nsx_data_center_f or_vsphere:-:*:*:*:*:*	CWE-611

Patch Links

<https://docs.vmware.com/en/VMware-NSX-Data-Center-for-vSphere/6.4.14/rn/vmware-nsx-data-center-for-vsphere-6414-release-notes/index.html>

<https://kb.vmware.com/s/article/89809>

References

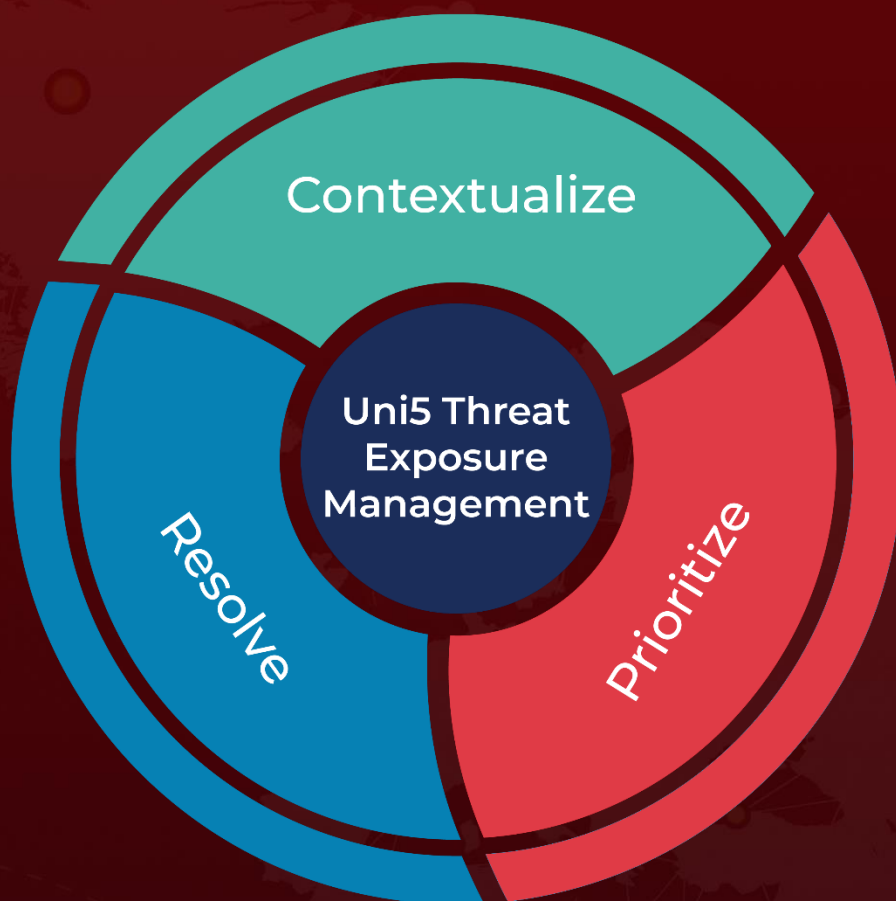
<https://www.vmware.com/security/advisories/VMSA-2022-0027.html>

<https://thehackernews.com/2022/10/vmware-releases-patch-for-critical-rce.html>

What Next?

At **HivePro**, it is our mission to detect the most likely threats to your organization and to help you prevent them from happening.

Book a free demo with **Hive Pro Uni5**: Continuous Threat Exposure Management Platform.



REPORT GENERATED ON

October 27, 2022 • 5:36 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com